CYBERHUNTER AI

Platform Automated Security Testing & Bug Bounty

Mendeteksi kerentanan OWASP Top 10 secara aktif & pasif — dari crawling, injeksi, hingga verifikasi berbasis browser

oleh **Nastain** · Ternakheck

Masalah

- Scanner keamanan umumnya mahal, rumit, atau hanya mendeteksi **pasif** (headers, banner)
- Bug bounty butuh **active probing**: SQLi, XSS, command injection — yang sulit dilakukan manual pada website besar
- Crawler konvensional melewatkan parameter tersembunyi: POST body, JSON API, field hidden, endpoint yang tidak ter-link
- Situs modern memakai anti-bot JS challenge (WAF splash) yang membuat scanner biasa buta total
- Hasil scan mentah sulit dibaca — butuh evidence, payload persis, dan laporan siap-kirim

Satu platform web untuk security testing terotorisasi:

CRAWLER CERDAS

Crawl multi-halaman, subdomain, form, JS bundle — plus **parameter mining** (±75 nama param umum) dan **filename mutation** untuk endpoint tersembunyi.

ACTIVE + PASSIVE OWASP TOP 10

SQLi (error/blind/UNION extraction), XSS (reflected/stored/DOM via headless browser), command injection, LFI, SSRF, XXE, open redirect, CORS, security headers, exposed secrets.

ANTI-BOT SOLVER

Challenge JavaScript (WAF splash) diselesaikan otomatis via headless Chromium — clearance cookie dibawa ke request berikutnya.

REPORT & EVIDENCE

Setiap temuan menyimpan payload pemicu, parameter, endpoint, request/response mentah, severity, confidence — diekspor sebagai laporan HTML bilingual (EN/ID)

Cakupan Parameter — "Jangan Ada yang Kelewat"

Sumber Parameter	Status
Query string (semua link crawled)	✓
Form GET/POST — input, select, textarea, hidden non-CSRF	✓
JSON & XML body (API endpoints)	✓
HTTP headers (UA, Referer, X-Forwarded-*)	✓
Cookies	✓
Param tersembunyi di file .js (fetch/axios/route)	✓ JS mining
Param nama umum di endpoint tanpa query	✓ Parameter mining (±75 nama)
Endpoint file tak terduga (cetak/, unduh/, detail.php…)	✓ Wordlist + subdir probing + filename mutation

Deteksi Vulnerability

CYBERHUNTER AI

SQL INJECTION

Error-based (multi-DBMS pattern), **time-based blind** dengan konfirmasi ganda anti-false-positive, dan **UNION extraction** hingga 15 kolom dengan marker database.

XSS

Reflected, stored, dan **DOM XSS diverifikasi via browser headless** — payload harus benar-benar mengeksekusi, bukan sekadar ter-reflect.

COMMAND INJECTION

Marker aritmatika `CYBERHUNTER_$((7*7))` → output `CYBERHUNTER_49` — mustahil muncul dari refleksi biasa.

CVE SURFACE

Fingerprint versi PHP/CMS → ruleset CVE (php2shell CVE-2026-109618/619, Drupalgeddon2, Joomla, Laravel, WordPress, phpMyAdmin, ThinkPHP…) + verifikasi aktif read-only.

Arsitektur

```
Frontend — React + TypeScript + Vite (Dashboard, Scan, Findings, AI Config, Reports)
Backend — Node.js + Express
  ├─ crawler.js  : crawl, extract links/forms/params, anti-bot challenge solver (Puppeteer)
  ├─ scanner.js : probe engine OWASP Top 10, parameter mining, adaptive timeout
  ├─ cve.js     : fingerprint teknologi + ruleset CVE + php2shell probe
  ├─ domxss.js : verifikasi DOM XSS via Chromium
  └─ db.js      : persistence JSON (findings, providers, logs)
AI Layer — multi-provider (OpenAI-compatible, Anthropic, Gemini, Ollama, LM Studio, EdgeOne) untuk
analisis & laporan
```

Teknologi

FRONTEND

React 18, TypeScript, Vite, React Router — dark-theme dashboard, live scan log streaming, grafik severity yang bisa diklik.

BACKEND

Node.js ES modules, Express, undici fetch manual-redirect, Puppeteer (Chromium) untuk challenge solver & DOM verification.

DETEKSI

~90 payload SQLi/XSS/cmdi/LFI/SSRF/XXE, 75+ nama parameter mining, 60+ path wordlist + filename mutation, adaptive timeout untuk target lambat/WAF.

AI PROVIDERS

6 provider model (cloud & lokal) — konfigurasi per-provider, model selector, playground, usage logs terenkripsi.

Hasil & Bukti

- Scan aktif terhadap aplikasi PHP gov (PPID Brebes) menemukan **40+ parameter injectable** — SQL error "Illegal mix of collations" terkonfirmasi manual
- Scan terhadap situs Joomla ber-WAF (PA Sibolga): anti-bot challenge ter-solve otomatis, crawl berhasil menembus splash page
- Setiap finding menyimpan: **URL, parameter, lokasi (query/body/header/cookie), payload persis, evidence, request & response mentah**
- Export laporan HTML bilingual (EN/ID) format XRay — summary table + detail Request1/Response1 per finding
- Findings persisten di database lokal + dashboard severity chart + filter

Etika & Keamanan

- Active probing **hanya untuk sistem milik sendiri atau dengan otorisasi tertulis** — gating eksplisit di UI
- Cookie session di-scope per-origin — tidak pernah bocor ke domain lain
- Nilai cookie disensor di log, database, dan laporan export
- Payload non-destruktif: marker aritmatika, canary string, error-based — tanpa exploit berbahaya
- robots.txt disrespect — deteksi "Disallow: /" menghasilkan peringatan scope
- Rate limiting via request delay yang dapat diatur (0–500ms+)

Roadmap

- **Jangka pendek**: Nuclei template integration, authenticated scan wizard, report PDF export
- **Menengah**: distributed scanning queue, authenticated crawling (login multi-step), GraphQL fuzzing mendalam
- **Jangka panjang**: plugin system untuk check custom, integrasi bug-bounty platform (HackerOne/Bugcrowd scope sync), AI-assisted triage findings

TERIMA KASIH

CYBERHUNTER AI — github.com/nastainannas/cyberhunter-ai